

Security+ 2.2 · Watering Hole

Mestre CyberSec — Guia Completo CompTIA Security+ (SY0-701) · **Aula 2.2 — Watering Hole (4:12)** · [Vídeo Oficial no YouTube ↗](#) · [Página no Professor Messer ↗](#)

Resumo Executivo da Aula: Compromete site que tu e teus colegas JÁ usam (forum de indústria, portal de hotel) — espera tu 'beber água' lá. Não ataca tu diretamente; usa o tráfego natural pra entregar o payload.

Highlights que a prova cobra

- Não compromete a rede da vítima — compromete um TERCEIRO site que tu confia
- Espera tu vir: o 'bebedouro' é onde o alvo já vai naturalmente

Dicas de prova & Cenários Típicos

- 'compromised a website frequented by the target group' = watering hole

Cenário clássico de exame: Cenário: 'atacante compromete forum de uma indústria pra infectar os membros' = watering hole.

Além do Vídeo: O que a CompTIA cobra na prova (Conceitos, Siglas e Armadilhas da Aula 2.2 — Watering Hole)

Por que este aprofundamento é cobrado no exame? O vídeo do Professor Messer apresenta uma introdução ágil. Porém, a banca oficial CompTIA Security+ (SY0-701) exige raciocínio de engenharia prática e cobra diretamente os seguintes protocolos, jargões e ferramentas no contexto desta aula:

- **Princípio do Menor Privilégio:** Usuários e sistemas devem ter apenas as permissões estritamente necessárias para suas funções corporativas.
- **Defesa em Profundidade (Defense-in-Depth):** Aplicação de múltiplas camadas de controles (técnicos, administrativos, físicos) para evitar que a falha de um exponha todo o ambiente.

Armadilhas e Pegadinhas Clássicas da Banca:

- Nunca decore apenas letras ou siglas: a CompTIA altera o cenário exigindo que você justifique por que o controle escolhido é o *MAIS adequado* dentre 4 opções válidas.
- Fique atento às restrições do enunciado: 'sem custo adicional' favorece configurações nativas do SO; 'maior granularidade de rede' favorece TACACS+ em vez de RADIUS; 'não-repúdio' exige chave privada/assinatura digital.

Perguntas de treino comentadas (10 questões)

Gabarito com resolução passo a passo e análise técnica individual de cada distrator no fim. Tente responder antes de olhar.

1. Um atacante usa RFID para clonar crachás de funcionários e acessar áreas restritas. Que tipo de ataque físico é esse?

- A)** Tailgating
- B)** Shoulder surfing
- C)** Clonagem de credenciais
- D)** Dumpster diving

2. Comprometer um fornecedor de software pra atingir todos os clientes dele (ex: SolarWinds):

- A)** Ataque de cadeia de suprimentos
- B)** Watering hole
- C)** Insider
- D)** Zero-day

3. Cenário corporativo (Watering Hole): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.2), um analista avalia o seguinte requisito técnico: 'Não compromete a rede da vítima — compromete um TERCEIRO site que tu confia'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: Não compromete a rede da vítima — compromete um TERCEIRO site que tu confia...

4. Cenário corporativo (Watering Hole): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.2), um analista avalia o seguinte requisito técnico: 'Espera tu vir: o 'bebedouro' é onde o alvo já vai naturalmente'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: Espera tu vir: o 'bebedouro' é onde o alvo já vai naturalmente...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

5. Cenário corporativo (Watering Hole): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.2), um analista avalia o seguinte requisito técnico: 'compromised a website frequented by the target group' = watering hole'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: 'compromised a website frequented by the target group' = watering hole...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

6. Cenário corporativo (Watering Hole): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.2), um analista avalia o seguinte requisito técnico: 'Cenário: 'atacante compromete forum de uma indústria pra infectar os membros' = watering hole.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: Cenário: 'atacante compromete forum de uma indústria pra infectar os membro...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

7. Cenário corporativo (Watering Hole): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.2), um analista avalia o seguinte requisito técnico: 'Não compromete a rede da vítima — compromete um TERCEIRO site que tu confia'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: Não compromete a rede da vítima — compromete um TERCEIRO site que tu confia...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

8. Cenário corporativo (Watering Hole): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.2), um analista avalia o seguinte requisito técnico: 'Espera tu vir: o 'bebedouro' é onde o alvo já vai naturalmente'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: Espera tu vir: o 'bebedouro' é onde o alvo já vai naturalmente...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

9. Cenário corporativo (Watering Hole): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.2), um analista avalia o seguinte requisito técnico: 'compromised a website frequented by the target group' = watering hole'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: 'compromised a website frequented by the target group' = watering hole...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

10. Cenário corporativo (Watering Hole): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.2), um analista avalia o seguinte requisito técnico: 'Cenário: 'atacante compromete forum de uma indústria pra infectar os membros' = watering hole.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: Cenário: 'atacante compromete forum de uma indústria pra infectar os membro...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

GABARITO COMENTADO COM ANÁLISE DETALHADA DOS DISTRATORES

1) C — Clonagem de credenciais.

✓ **Por que está certa:** A alternativa correta é 'Clonagem de credenciais'. A clonagem de credenciais ocorre quando um atacante copia os dados de um cartão de acesso (como crachás RFID ou cartões de proximidade) para outro dispositivo, permitindo acesso não autorizado. No cenário, o uso de RFID para copiar o sinal do crachá e replicá-lo em um cartão virgem é um exemplo clássico de clonagem de credenciais físicas. A CompTIA Security+ aborda ataques físicos e contramedidas, como o uso de cartões com criptografia ou autenticação mútua para prevenir clonagem.

✗ **Por que as outras estão erradas:**

- *Tailgating:* Tailgating é a prática de seguir fisicamente uma pessoa autorizada através de uma porta segura sem usar credenciais próprias. Não envolve clonagem de cartões ou RFID; é uma intrusão física passiva. A alternativa é incorreta porque o enunciado descreve a cópia eletrônica de credenciais, não a entrada por proximidade.
- *Shoulder surfing:* Shoulder surfing é a observação direta por cima do ombro para obter informações como senhas ou PINs. Não envolve RFID ou clonagem de crachás. A alternativa é incorreta porque é uma técnica de observação visual, não de duplicação eletrônica.
- *Dumpster diving:* Dumpster diving é a busca em lixeiras por informações descartadas (documentos, mídias) que possam ser úteis ao atacante. Não tem relação com RFID ou clonagem de credenciais. A alternativa é incorreta porque se trata de recuperação de dados descartados, não de interceptação e cópia de sinais de cartão.

2) A — Ataque de cadeia de suprimentos.

✓ **Por que está certa:** Ataque de cadeia de suprimentos (supply chain attack) ocorre quando um adversário compromete um fornecedor, parceiro ou componente de software/hardware para atingir os clientes finais desse fornecedor. No caso SolarWinds (2020), atacantes comprometeram o processo de build do software Orion, inserindo código malicioso que foi distribuído como atualização legítima a milhares de clientes, incluindo agências governamentais. Esse é o exemplo clássico de ataque à cadeia de suprimentos, conforme descrito no objetivo SY0-701 2.2 (ameaças à cadeia de suprimentos) e 2.3 (vetores de ataque). A questão descreve exatamente esse cenário: comprometer um fornecedor de software para atingir todos os clientes dele.

✗ **Por que as outras estão erradas:**

- *Watering hole:* Watering hole é um ataque em que o adversário compromete um site legítimo frequentado por um grupo específico de vítimas (ex.: site de um setor industrial) e insere código malicioso para infectar os visitantes. O objetivo é atingir usuários que visitam aquele site, não comprometer um fornecedor de software para distribuir malware a todos os seus clientes. No watering hole, o vetor é o site de terceiros visitado pelas vítimas; na cadeia de suprimentos, o vetor é o próprio produto ou atualização do fornecedor. A questão fala em comprometer um fornecedor de software para atingir todos os clientes dele, o que é supply chain, não watering hole.
- *Insider:* Ameaça interna (insider threat) refere-se a um indivíduo com acesso autorizado (funcionário, contratado, parceiro) que usa esse acesso para causar dano, roubar dados ou facilitar ataques. O atacante é interno à organização, não um fornecedor externo comprometido. No caso SolarWinds, os atacantes eram externos (APT29) que comprometeram a cadeia de suprimentos da SolarWinds; não se trata de um insider da SolarWinds ou dos clientes. Portanto, insider não descreve o cenário de comprometer um fornecedor para atingir seus clientes.
- *Zero-day:* Zero-day refere-se a uma vulnerabilidade desconhecida pelo fornecedor, para a qual não há patch disponível. O ataque explora essa falha antes que seja corrigida. Embora ataques à

cadeia de suprimentos possam envolver zero-days, o conceito de zero-day é sobre a natureza da vulnerabilidade, não sobre o vetor de comprometer um fornecedor para atingir clientes. No caso SolarWinds, o ataque não dependeu exclusivamente de uma zero-day; envolveu comprometimento do processo de build e distribuição de atualização maliciosa. A questão pede o nome do ataque que compromete um fornecedor para atingir todos os clientes, que é supply chain, não zero-day.

3) D — Implementar a solução correspondente: Não compromete a rede da vítima — compromete um TERCEIRO site que tu confia....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.2 (Watering Hole): Não compromete a rede da vítima — compromete um TERCEIRO site que tu confia.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

4) A — Implementar a solução correspondente: Espera tu vir: o 'bebedouro' é onde o alvo já vai naturalmente....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.2 (Watering Hole): Espera tu vir: o 'bebedouro' é onde o alvo já vai naturalmente.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

5) B — Implementar a solução correspondente: 'compromised a website frequented by the target group' = watering hole....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.2 (Watering Hole): 'compromised a website frequented by the target group' = watering hole.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são

controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.

- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

6) C — Implementar a solução correspondente: Cenário: 'atacante compromete forum de uma indústria pra infectar os membro....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.2 (Watering Hole): Cenário: 'atacante compromete forum de uma indústria pra infectar os membros' = watering hole..

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

7) A — Implementar a solução correspondente: Não compromete a rede da vítima — compromete um TERCEIRO site que tu confia....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.2 (Watering Hole): Não compromete a rede da vítima — compromete um TERCEIRO site que tu confia.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

8) C — Implementar a solução correspondente: Espera tu vir: o 'bebedouro' é onde o alvo já vai naturalmente....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.2 (Watering Hole): Espera tu vir: o 'bebedouro' é onde o alvo já vai naturalmente.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam

ataques automatizados, injeções ou malwares em tempo de execução.

- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

9) C — Implementar a solução correspondente: 'compromised a website frequented by the target group' = watering hole....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.2 (Watering Hole): 'compromised a website frequented by the target group' = watering hole.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

10) A — Implementar a solução correspondente: Cenário: 'atacante compromete forum de uma indústria pra infectar os membros....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.2 (Watering Hole): Cenário: 'atacante compromete forum de uma indústria pra infectar os membros' = watering hole..

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.